

SOP – Datenschutz & Datenaufbewahrung (CFlux)

Version: 1.1 (Entwurf) · Stand: 2026-08-26 · Verantwortlich: Philipp Amacker (Datenschutzverantwortlicher)
· Matthias Püschi (operative Durchführung, IT-Betrieb)

Regelt den Umgang mit personenbezogenen Daten in CFlux gemäß DSGVO bzw. CH-DSG (revDSG).

Hinweis: Diese SOP ersetzt keine Rechtsberatung. Fristen und Rechtsgrundlagen mit dem/der Datenschutzverantwortlichen bzw. der Rechtsabteilung final festlegen.

Änderungshinweis (v1.0 → v1.1): Überarbeitung auf Basis des Feedbacks von Philipp Amacker vom 13.07.2026 (Verantwortlichkeiten, Speicherorte, technische Massnahmen, Schulungen, Datenfluss).
Neu bzw. erweitert: §3, §5, §6, §9, §10. **Entwurfsstatus – zur Prüfung durch Rado und Philipp vorgelegt.**

1. Zweck & Geltungsbereich

Rechtskonforme Verarbeitung, Aufbewahrung und Löschung personenbezogener Daten, die CFlux verarbeitet – insbesondere Mitarbeiter-, Bewerber- und Zeitdaten.

2. Datenkategorien in CFlux

Kategorie	Beispiele	Sensibilität
Stammdaten Mitarbeiter	Name, Adresse, Telefon, Personalnummer	hoch
Sozialdaten	AHV-Nummer, Grenzgänger-Status	besonders schützenswert
Finanzdaten	Bankverbindung	hoch
Zeit-/Leistungsdaten	Zeiteinträge, Projekte, Überstunden	hoch (Verhaltenskontrolle)
Bewerberdaten	Bewerbungen, Dokumente, Interview-Notizen	hoch
Gesundheitsbezug	Abwesenheiten (Krankheit)	besonders schützenswert
E-Learning/Onboarding	Kursfortschritt, Onboarding-Aufgaben	mittel

3. Verantwortlichkeiten (RACI)

(neu, Antwort auf Philipps Feedback Punkt 1)

Prozess	Verantwortlich (R)	Rechenschaftspflichtig (A)	Konsultiert (C)	Informiert (I)
Auskunftsersuchen entgegennehmen & Identität prüfen	Matthias (IT-Betrieb)	Philipp (DSB)	–	Rado
Auskunft zusammenstellen	Matthias	Philipp	–	–

Prozess	Verantwortlich (R)	Rechenschaftspflichtig (A)	Konsultiert (C)	Informiert (I)
(Daten aus Modulen)				
Berichtigungsanfrage bearbeiten	Matthias	Philipp	–	–
Entscheidung über Löschung (Aufbewahrungspflicht prüfen)	Philipp (DSB)	Philipp	Matthias (kennt Datenbestand)	Rado
Löschung technisch durchführen	Matthias	Philipp	–	–
Antwort an Betroffene dokumentieren	Matthias	Philipp	–	–
Regelmässige Einhaltungsprüfung (jährlich)	Philipp	Rado	Matthias	–
VVT pflegen/aktualisieren	Matthias (bei neuen Modulen)	Philipp	–	–
Datenschutzvorfall bewerten & Meldepflicht prüfen	Philipp	Rado (Freigabe externe Kommunikation)	Matthias	Geschäftsleitung

4. Grundsätze

- **Zweckbindung & Datenminimierung:** Nur Daten erheben, die benötigt werden.
- **Zugriffsbeschränkung:** Sensible Module (HR, Lohn, Bewerber) nur an berechtigte Gruppen (siehe SOP Benutzer- & Zugriffsverwaltung).
- **Vertraulichkeit:** Datenbank-Port nur intern (**127.0.0.1**), Transport per HTTPS.
- **Nachvollziehbarkeit:** Zugriffe/Änderungen über Audit-Log.

5. Speicherorte der Daten

(neu, Antwort auf Philipps Feedback Punkt 2)

Datenart	Speicherort	Land/Region
Datenbank (PostgreSQL, alle Kernmodule)	Cloud-Server, Volume postgres_data	EU – Hetzner Online GmbH, Deutschland
Dokumente/Anhänge (Uploads)	selber Server, Volume backend_uploads	EU – Hetzner, Deutschland
Automatische/manuelle Backups	selber Server, Volume backend_backups	EU – Hetzner, Deutschland

Datenart	Speicherort	Land/Region
Off-Site-Sicherung (zusätzlicher Backup-Standort)	Noch nicht umgesetzt – geplant	TBD

Solange keine Off-Site-Sicherung besteht, besteht bei Ausfall/Kompromittierung des Hosts ein erhöhtes Risiko für Datenverlust (siehe Betriebs-SOP §6.3, dort bereits als Empfehlung vermerkt). Umsetzung der Off-Site-Sicherung sollte mit Zieldatum versehen werden.

Da Hetzner eine deutsche Gesellschaft ist (Speicherort EU), liegt kein Drittlandtransfer vor. Zu prüfen bleibt: **Auftragsverarbeitungsvertrag (Art. 28 DSGVO) mit Hetzner** vorhanden/aktuell?

6. Technische und organisatorische Massnahmen (TOM)

(neu, Antwort auf Philipps Feedback Punkt 3)

Massnahme	Status	Referenz/Detail
Verschlüsselung (Transport)	✓ Umgesetzt	HTTPS für alle Verbindungen
Verschlüsselung (at Rest)	✓ Umgesetzt	Festplattenverschlüsselung durch Hetzner-Hosting aktiv
Backup- & Recovery-Konzept	✓ Dokumentiert	siehe Betriebs-SOP §6 (Off-Site-Sicherung: siehe §5, geplant)
Patch-/Update-Management	✓ Dokumentiert	siehe Betriebs-SOP §4.3 (monatlich), §9 (Deployment)
Berechtigungs-/Rollenmodell	✓ Dokumentiert	siehe SOP Benutzer- & Zugriffsverwaltung
Firewall/Netzwerkkonzept	⚠ Teilweise	DB-Port nur intern (127.0.0.1), Reverse Proxy/TLS vor Frontend (Betriebs-SOP §8). Kein dediziertes Host-Firewall-Konzept dokumentiert
MFA	✗ Nicht umgesetzt	Aktuell kein Mehrfaktor-Schutz für CFlux-Logins
Endpoint-Schutz	⚠ Basis-Niveau	Nur Windows Defender (Standard), keine zentral verwaltete EDR-Lösung
Passwortvorgaben	⚠ Minimal	Aktuell nur Mindestlänge 6 Zeichen (SOP Passwort-Reset §3) – keine Komplexitätsvorgabe

Risikohinweis: Fehlende MFA und die geringe Passwort-Mindestlänge (6 Zeichen) sind die relevantesten offenen Sicherheitslücken im aktuellen Setup, insbesondere da CFlux sensible HR-/Lohndaten verarbeitet. Empfehlung: MFA zumindest für ADMIN-Rollen priorisieren, Passwort-Mindestlänge auf 10–12 Zeichen anheben. Endpoint-Schutz über Windows-Defender-Basis hinaus (zentrale Verwaltung/EDR) mittelfristig prüfen.

7. Aufbewahrung & Löschung

Fristen sind Vorschläge – organisationsspezifisch verbindlich festlegen.

Datenart	Empfohlene Aufbewahrung	Aktion danach
Bewerberdaten (Absage)	3–6 Monate nach Absage (CH: bis 3 Monate; Nachweispflichten beachten)	Löschen/Anonymisieren
Mitarbeiterdaten	Dauer Beschäftigung + gesetzl. Fristen (Lohn/Steuer i. d. R. bis 10 Jahre)	Prüfen, dann löschen
Zeiterfassungsdaten	Gesetzl. Aufbewahrung (CH ArG: 5 Jahre)	Archivieren/löschen
Rechnungen	10 Jahre (Buchführung)	Aufbewahren
Abwesenheiten (Gesundheit)	Nur solange erforderlich	Minimieren/löschen

Löschprozess:

1. Betroffene Datensätze identifizieren (Modul/DB).
2. Prüfen, ob gesetzliche Aufbewahrung entgegensteht.
3. Löschen bzw. anonymisieren; Vorgang dokumentieren (was, wer, wann, Rechtsgrundlage).
4. Beachten: **Backups** enthalten die Daten ebenfalls – Löschung wirkt erst nach Ablauf der Backup-Retention vollständig. Retention entsprechend dokumentieren.

8. Betroffenenrechte (Auskunft, Berichtigung, Löschung)

1. Antrag entgegennehmen, **Identität prüfen** — *verantwortlich: Matthias*.
2. Frist: DSGVO i. d. R. **1 Monat**.
3. Auskunft: Zusammenstellung der zur Person gespeicherten Daten aus den Modulen — *verantwortlich: Matthias, Freigabe: Philipp*.
4. Berichtigung: Daten korrigieren, Änderung dokumentieren — *verantwortlich: Matthias*.
5. Löschung: nach §7-Prozess, sofern keine Aufbewahrungspflicht besteht — *Entscheidung: Philipp; Durchführung: Matthias*.
6. Antwort dokumentieren (Datum, Bearbeiter, Ergebnis) — *verantwortlich: Matthias*.

9. Mitarbeiterschulungen

(neu, Antwort auf Philipps Feedback Punkt 4)

Aspekt	Status
Schulung beim Eintritt	⚠️ Aktuell Teil des allgemeinen Onboardings, aber nicht formalisiert – kein eigenständiger, dokumentierter Datenschutz-Baustein
Auffrischungsschulung	❌ Turnus noch nicht festgelegt (offen)
Dokumentation der Teilnahme	❌ Aktuell nicht vorgesehen
Verantwortlich	Philipp Amacker (DSB)

Neue Mitarbeitende erhalten im Rahmen des Onboardings eine Einweisung zum Umgang mit personenbezogenen Daten (Zweckbindung, Datenminimierung, Meldung von Vorfällen). Verantwortlich für Inhalt und Durchführung: Philipp Amacker (Datenschutzverantwortlicher).

Offener Punkt: Der Onboarding-Baustein ist bisher nicht als eigenständige, dokumentierte Schulungseinheit formalisiert (kein festes Material, keine Teilnahmebestätigung). Ebenso ist der Turnus für Auffrischungsschulungen noch nicht festgelegt.

Empfehlung: Kurze schriftliche Kurzunterlage (1–2 Seiten) erstellen, Teilnahme per Unterschrift/E-Mail-Bestätigung dokumentieren; Turnus für Auffrischung (z. B. jährlich) in einer der nächsten Reviews festlegen.

10. Datenfluss & Auftragsverarbeiter/Drittdienste

(erweitert, Antwort auf Philipps Feedback Punkt 5)

Datenfluss (Erfassung → Verarbeitung → Speicherung → Löschung):

Phase	Beschreibung
Erfassung	Eingabe direkt in CFlux durch Mitarbeitende/Admin (Stammdaten, Zeiterfassung) bzw. über Bewerbungsformular (Bewerberdaten)
Verarbeitung	Innerhalb CFlux-Backend (Node/Prisma), PDF-Erzeugung über Gotenberg (lokal, keine externe Übermittlung)
Speicherung	PostgreSQL-Datenbank + Uploads-Volume, Hetzner-Server (EU/Deutschland), s. §5
Übermittlung an Dritte	Nur an dokumentierte Auftragsverarbeiter (s. Tabelle unten)
Löschung	Gemäss §7 (Aufbewahrung & Löschung), inkl. Backup-Retention

Schnittstellen-/Drittdienste:

Dienst	Zweck	Datenkategorie	AV-Vertrag
Action1	Geräte-/Software-Inventar	Endgeräte-, Nutzungsdaten (personenbezogen über Gerätezuordnung)	zu prüfen
Gotenberg	PDF-Erzeugung	läuft lokal im Netzwerk, keine externe Übermittlung	entfällt
E-Mail-Dienstleister	Passwort-Reset, Bewerber-Mails	E-Mail-Adressen, Namen	zu prüfen
Hetzner (Hosting)	Server-/Speicherinfrastruktur	alle in CFlux gespeicherten Daten	zu prüfen

Klarstellung: Munixo (Leistungsnachweise) und Revolut (Spesenabrechnung) sind eigenständige, von CFlux **unabhängige Systeme** ohne Datenaustausch mit CFlux – daher nicht Teil dieser SOP.

Offener Punkt: Eine Schnittstelle zu Lohn-/Treuhandsoftware ist in Planung, aber noch nicht final spezifiziert. Sobald umgesetzt, ist diese Tabelle sowie das VVT (§12) zu aktualisieren.

11. Datenschutzvorfall

- Bei (mutmaßlichem) Verlust/Offenlegung personenbezogener Daten: → **SOP Security Incident Response** auslösen.
- **Meldepflicht: DSGVO 72 Stunden** an die Aufsichtsbehörde (CH revDSG: „so rasch als möglich“), falls Risiko für Betroffene. Datenschutzverantwortlichen sofort informieren.

12. Verzeichnis von Verarbeitungstätigkeiten (VVT)

- CFlux als Verarbeitungstätigkeit im VVT führen (Zweck, Kategorien, Empfänger, Fristen, TOMs). Bei neuen Modulen/Integrationen aktualisieren.

13. Referenzen

- [docs/security.md](#), [docs/SWISS_COMPLIANCE_CHECKLIST.md](#)
- SOP Benutzer- & Zugriffsverwaltung, SOP Security Incident Response
- Betriebs-SOP ([docs/SOP-BETRIEB.md](#)) – Backups/Retention